

Seguridad en Sistemas Operativos

Privilegios, permisos, parches y bastionado en Linux y Windows. La capa donde se ganan o se pierden la mayoría de los compromisos.

• 17 diapositivas

~25 min

Nivel • Iniciación + Práctica

```
| 0x02 • KERN |  
  
|| ring 0 || ← kernel  
|| ring 3 || ← userland  
  
[ usuarios ]  
[ permisos ]  
[ hardening ]
```

Qué vamos a ver

/01	Por qué el SO es la primera línea	contexto
/02	Anatomía del SO & modelo de privilegios	kernel · userland
/03	Usuarios y grupos · Linux y Windows	2 slides
/04	Permisos de archivos · Linux y NTFS	2 slides
/05	Elevación de privilegios · sudo / UAC	control
/06	Parches y actualizaciones	gestión de CVEs
/07	Hardening · checklist Linux y Windows	2 slides
/08	Servicios, puertos y logs	superficie
/09	Lab · hardening básico en VM	manos a la obra

03 · EL SO ES LA PRIMERA LÍNEA

Sin un SO endurecido, cualquier control superior es papel mojado: el sistema operativo gobierna usuarios, ficheros, procesos, red y memoria.

Síntesis a partir de NIST SP 800-123 – Guide to General Server Security [1]

CIS · Center for Internet Security · Benchmarks

CCN-STIC · Series 619 (Windows) y 642 (RHEL)

DISA · STIGs (Security Technical Implementation Guides)

Anillos de protección

Los procesadores x86 separan el código en niveles de privilegio. El SO usa dos de ellos: kernel y usuario.

// ring 0

Kernel space

acceso total ·
drivers ·
syscalls

// ring 3

User space

tu navegador,
tu shell, tus
apps

▲ Un atacante con acceso a **ring 0** tiene control absoluto. Por eso buena parte de la ciberdefensa consiste en evitar que un proceso en ring 3 escale a ring 0.

Usuarios y grupos en Linux

Linux

// POSIX

cuentas	Definidas en <code>/etc/passwd</code> . Contraseñas hasheadas en <code>/etc/shadow</code> (root-only).
identificador	UID numérico. <code>UID 0</code> = root. UIDs < 1000 reservados al sistema.
grupos	Un grupo primario + N secundarios. Definidos en <code>/etc/group</code> .
crear	<code>useradd -m -s /bin/bash alice</code> <code>passwd alice</code>
listar	<code>id alice</code> <code>getent passwd</code> <code>groups alice</code>

Cuentas clave

// system

- `root` · UID 0 · superusuario, sin restricciones.
- `daemon`, `www-data`, `sshd` · cuentas de servicio, sin shell.
- `nobody` · proceso sin privilegios para tareas aisladas.
- Usuarios "humanos" arrancan en `UID 1000` en Debian/Ubuntu.

Usuarios y grupos en Windows

Windows		// SAM / AD
cuentas locales	Almacenadas en la SAM (Security Account Manager). Hashes NTLM.	
identificador	SID (Security Identifier). El de Administrador termina en -500 .	
grupos clave	Administrators, Users, Remote Desktop Users, Backup Operators.	
crear	New-LocalUser "alice" Add-LocalGroupMember Users alice	
dominio (AD)	Domain Admins, Enterprise Admins = control total del dominio o bosque.	

Cuentas clave		// builtin
→	SYSTEM · contexto del kernel · todopoderoso en local.	
→	Administrator · cuenta integrada, deshabilítala si no la usas.	
→	Guest · invitado · deshabilitado por defecto, mantenlo así.	
→	DefaultAccount, WDAGUtilityAccount · cuentas del sistema.	

Permisos POSIX: $rwX \cdot 3 \times 3$

// OWNER

Propietario **rWx** **= 7**

read · write · execute para el usuario
dueño del archivo.

// GROUP

Grupo **$r-X$** **= 5**

read · execute para los miembros del
grupo dueño.

// OTHERS

Resto del mundo **$r--$** **= 4**

sólo lectura para cualquier otro usuario
del sistema.

```
$ chmod 754 script.sh → rwxr-xr--
```

bit especial · **SUID (4xxx)** ejecuta como el dueño · **SGID (2xxx)** hereda grupo · **sticky (1xxx)** sólo el
dueño borra (/tmp).

ACLs en NTFS

Windows no usa rwx: cada objeto tiene una lista de control de acceso con entradas (ACE) por usuario o grupo.

Permisos estándar

// NTFS

- **Full Control** · lectura, escritura, borrado y cambio de permisos.
- **Modify** · lectura + escritura + borrado del propio objeto.
- **Read & Execute** · ejecutar archivos y listar carpetas.
- **Write** · crear o sobrescribir contenido.
- **Read** · sólo lectura del objeto y sus atributos.

Conceptos clave

// ACL

- **DACL** · discretionary · "quién puede hacer qué".
- **SACL** · system · "qué eventos se auditan".
- **Herencia** · los permisos fluyen del padre al hijo, salvo bloqueo explícito.
- **icaccls** · herramienta CLI para inspeccionar y modificar ACLs.

Elevación controlada de privilegios

Nadie debería operar como root o Administrator a diario. Ambos SO ofrecen mecanismos para elevar sólo cuando hace falta.

Linux · sudo		// /etc/sudoers
qué hace	Ejecuta un comando con privilegios de otro usuario (típicamente root) tras autenticar.	
configurar	visudo · edita /etc/sudoers con sintaxis verificada.	
grupo típico	sudo (Debian/Ubuntu) o wheel (RHEL/Arch).	
buena práctica	Reglas específicas por comando · evitar NOPASSWD · registrar con sudoreplay.	

Windows · UAC		// runas
qué hace	User Account Control separa el token estándar del token elevado. El usuario consiente la elevación.	
cli	runas /user:Administrator cmd.exe PowerShell: Start-Process -Verb RunAs.	
tokens	Estándar (medium IL) y elevado (high IL). El elevado lleva el grupo Administrators activo.	
buena práctica	UAC siempre en Always notify. Usar LAPS para rotar contraseñas de admin local.	

Actualizar es la mitigación nº1

La inmensa mayoría de los compromisos explota vulnerabilidades para las que **ya existe parche**.

~28.000

CVEs nuevos publicados en 2023 en la base de datos NVD del NIST — récord histórico. [2]

9,3%

de las vulnerabilidades del periodo 2023-24 se clasificaron como **críticas** (ENISA). [3]

Linux · cómo aplicar parches // pkg mgr

debian apt update && apt upgrade ·
unattended-upgrades

rhel dnf upgrade · dnf-automatic

Windows · Patch Tuesday // WSUS

cadencia Microsoft publica parches el **2.º martes de cada mes**.

empresa **WSUS · Intune · Group Policy** para desplegar.

Checklist · Hardening Linux

[01]Deshabilitar login de root por SSH: <code>PermitRootLogin no</code> en <code>/etc/ssh/sshd_config</code> .	ssh
[02]Forzar autenticación por clave pública : <code>PasswordAuthentication no</code> .	ssh
[03]Firewall por defecto en deny : <code>ufw default deny incoming</code> · permitir sólo lo necesario.	net
[04]Eliminar paquetes innecesarios: <code>apt remove telnet rsh-server</code> · auditar con <code>apt list --installed</code> .	pkg
[05]Actualizaciones automáticas de seguridad: <code>unattended-upgrades</code> .	pkg
[06]Política de contraseñas + bloqueo: <code>/etc/security/pwquality.conf</code> + <code>faillock</code> .	auth
[07]Permisos correctos en archivos sensibles: <code>chmod 600 /etc/shadow</code> · <code>/etc/sudoers = 440</code> .	fs
[08]Auditoría con auditd + protección de fuerza bruta con fail2ban .	log

Checklist · Hardening Windows

[01]UAC siempre activo en nivel Always notify.No deshabilitar.	auth
[02]Windows Defender y SmartScreen habilitados · firmas al día.	av
[03]BitLocker en el disco del sistema con TPM + PIN.	disk
[04]Firewall activo en los 3 perfiles (Domain · Private · Public) con regla por defecto: bloquear entrante.	net
[05]Deshabilitar protocolos legados: SMBv1, NTLMv1, LLMNR, NetBIOS.	net
[06]Política de contraseñas vía GPO + bloqueo tras N intentos fallidos.	auth
[07]LAPS (Local Administrator Password Solution) para rotar la contraseña del admin local en cada máquina.	auth
[08]AppLocker o WDAC para limitar qué binarios se pueden ejecutar.	exec

Qué puertos están escuchando

Cada servicio expuesto es una puerta. Audita, cierra los que no uses y endurece los demás.

PUERTO	SERVICIO	FUNCIÓN	RIESGO TÍPICO	CÓMO VERLO
22/tcp	SSH	Acceso remoto cifrado	medio · fuerza bruta	ss -tlnp
80, 443/tcp	HTTP / HTTPS	Servidor web	medio · webapp	curl -I localhost
445/tcp	SMB	Compartición de archivos	alto · ransomware	Get-SmbShare
3389/tcp	RDP	Escritorio remoto Windows	alto · brute force	netstat -ano
23/tcp	Telnet	Acceso remoto sin cifrar	crítico · obsoleto	deberías cerrarlo ya

Logs y auditoría

Si no lo registras, no existe. Si no lo miras, tampoco. Saber dónde buscar es la mitad del trabajo.

Linux

// journald · syslog

autenticación

/var/log/auth.log (Debian) ·
/var/log/secure (RHEL)

sistema

journalctl -xe · /var/log/syslog

kernel

dmesg · /var/log/kern.log

auditd

Reglas en /etc/audit/rules.d/ · consulta
con ausearch.

Windows

// Event Viewer

canales clave

Application · System · Security

login OK

Event ID 4624 · login fallido 4625

cuenta nueva

Event ID 4720 · cambio de grupo 4732

cli

Get-WinEvent -LogName Security -
MaxEvents 50

Endurece tu Kali

// objeto
del lab
VM Linux
Kali ·
172.18.0.2

red NAT ·
docker

//
comparativa
Metasploitable2
172.18.0.3

QUÉ VAS A TOCAR

- › Crear un usuario no privilegiado y darle **sudo**.
- › Endurecer **SSH**: sin root, sin contraseñas.
- › Levantar **nftables** con política deny por defecto.
- › Comparar el estado de Metasploitable2 (todo abierto) con tu Kali endurecida.

●●● root@kali · ~/lab-02 · bash

[01] Verifica que openssh-server y nftables están activos (van por defecto en Kali):

```
$ systemctl status ssh nftables
```

[02] Crea un usuario no privilegiado y dale sudo:

```
$ adduser alumno && usermod -aG sudo alumno
```

[03] Endurece SSH en /etc/ssh/sshd_config:

→ PermitRootLogin no · PasswordAuthentication no

```
$ systemctl restart ssh
```

[04] Política nftables · denegar entrante por defecto y permitir SSH:

```
$ nft add table inet filter
```

```
$ nft 'add chain inet filter input { type filter hook input  
priority 0; policy drop; }'
```

```
$ nft add rule inet filter input tcp dport 22 accept
```

[05] Verifica y compara con Metasploitable2:

```
$ nft list ruleset · nmap -sV 172.18.0.3
```

6 ideas para llevarte

- /01 El SO gobierna usuarios, archivos, procesos y red: es la **primera línea** de defensa.
- /02 Kernel (ring 0) y userland (ring 3) separan privilegios. **Evitar la escalada** es la prioridad.
- /03 Linux: **UID/GID + rwx**. Windows: **SID + ACL en NTFS**. Distinto modelo, mismo objetivo.
- /04 Mínimo privilegio: **sudo** y **UAC** existen para no operar como root/Administrator a diario.
- /05 Actualizar es la mitigación nº1. Patch Tuesday y **unattended-upgrades** son tus aliados.
- /06 Bastionado = **checklist + benchmark** (CIS, CCN-STIC) + auditoría continua de logs.

SIGUIENTE · TEMA 03

Redes y Seguridad de Redes

La siguiente capa hacia afuera: protocolos, segmentación, firewalls, IDS/IPS, VPN y cómo se ve el tráfico cuando algo no va bien.

→ continúa en el siguiente vídeo

Para profundizar

Estándares y organismos oficiales. Toda la información proviene de fuentes verificables.

[1]	NIST SP 800-123	<i>Guide to General Server Security</i> · National Institute of Standards and Technology · csrc.nist.gov
[2]	NIST NVD	National Vulnerability Database · base oficial de CVEs · nvd.nist.gov
[3]	CIS	Center for Internet Security · <i>Benchmarks</i> para Linux, Windows y nube · cisecurity.org
[4]	CCN-CERT	Series CCN-STIC 619 (Windows) y 642 (RHEL) – guías oficiales de bastionado · ccn-cert.cni.es
[5]	Microsoft Learn	Documentación oficial: UAC, LAPS, Event Viewer, Security Baselines · learn.microsoft.com/security
[6]	INCIBE	Guías de bastionado para empresas · incibe.es